

Deliverable 2 — Intelligence Gathering · Détection précoce IT → OT, Marine Nationale

Joseph W. · 12 mai 2026 · Mission briefing

A · The OSINT Framework

Source Mapping

Notre intelligence se construit sur huit canaux open-source complémentaires, choisis pour leur autorité et leur fraîcheur. Le référentiel **MITRE ATT&CK**, accessible via flux STIX/TAXII, fournit la taxonomie complète des tactics et techniques d'attaquants — c'est la grammaire que nous utilisons pour modéliser les kill chains du notebook. Les flux quotidiens du **NIST National Vulnerability Database (NVD)** alimentent les scores CVSS et le matching CPE entre actif et CVE qui permet de filtrer les fausses cibles. Le catalogue **CISA Known Exploited Vulnerabilities (KEV)** sert de filtre du bruit : sur les 200 000 CVE recensées, seules environ 1 100 sont effectivement exploitées dans la nature, et c'est sur celles-là que nous concentrons la priorisation. En complément des sources américaines, les bulletins du **CERT-FR (ANSSI)** apportent la dimension souveraine et le focus défense français. La **doctrine publique du ComCyber** — Revue stratégique 2022, retours d'expérience FREMM/FDI — cadre l'intention métier. Enfin, les dépôts **GitHub de PoC**, les **advisories vendor** (Microsoft MSRC, Apache, Pulse Secure) et la **veille threat intel** (Sekoia.io, BleepingComputer, abuse.ch) nous donnent la maturité opérationnelle de chaque exploit et l'état des campagnes actives, notamment Sandworm et CyberAv3ngers qui ciblent activement les PLC depuis 2023.

Tooling

Notre stack technique reflète la nature de la cible. Le problème étant intrinsèquement un graphe (9 855 actifs, 20 000 dépendances), nous avons retenu **Python avec NetworkX** comme socle d'analyse : c'est l'outil natif pour les traversées multi-sauts, les calculs de centralité (PageRank pondéré pour identifier les hubs critiques), et la propagation BFS qui modélise la cascade. **Neo4j** est conservé comme format source, avec des requêtes Cypher en réserve pour les explorations complexes. Pour le pont entre événements et processus métier, **pandas associé à des expressions régulières** alimente notre **SemanticMapper**, dont le dictionnaire de connaissance reste explicitement éditable par un expert métier. L'interactivité est portée par **Plotly et ipywidgets**, choisis pour leur capacité à produire un dashboard riche sans déploiement web — un point important pour la souveraineté en environnement défense. Nous écartons délibérément Spark, Elasticsearch ou tout stack distribué : le volume ne le justifie pas, et la simplicité prime sur la sur-ingénierie. Toute la chaîne reste open-source et reproductible audit, ce qui est compatible doctrine défense et permet un déploiement air-gapped si nécessaire.

B · Dataset Inventory

Notre or tient en six sources principales, fraîchement collectées et toutes traçables. Le dataset `neo4j_dataset_50k`, fourni directement par la Marine Nationale comme cas d'école IT/OT, comporte 65 actifs en architecture Purdue, 50 000 événements et une attaque scriptée (`CVE-2021-41773` sur Apache 2.4.49) avec *ground truth* complète sur la fenêtre 11h–15h du 1^{er} mai 2026 — c'est notre baseline de validation des détecteurs. Le second dataset, `generalisation/`, daté du 12 mai 2026 et également fourni, passe à l'échelle d'un vrai système d'information d'entreprise : 9 855 actifs, 1 000 attaques (CVE et TTP confondues), 2 000 événements répartis sur cinq catégories (Alerte, Incident, Attaque Détectée, Panne Système, Maintenance) et 15 processus métier ; c'est sur lui que se construit la simulation de cascade et l'impact processus à grande échelle.

À ces deux sources internes s'ajoutent quatre référentiels publics. Le **MITRE ATT&CK Enterprise Matrix v15.1**, mis à jour en continu, fournit la séquence canonique des phases de kill chain qui pilote notre fonction `simulate_attack_chain` — sans lui, nous simulerions des exploits isolés au lieu de scénarios réalistes avec lateral movement entre phases. Les **flux NVD CVE quotidiens** du NIST nous donnent les scores CVSS détaillés et permettent le matching CPE : quand le `cpe` d'un actif ne correspond pas au CPE attaquant d'une CVE, nous pouvons filtrer la cible comme fausse positive avant de lancer la cascade. Le **catalogue CISA KEV**, actualisé quotidiennement, joue le rôle de filtre de priorisation et distingue les CVE théoriquement dangereuses des CVE réellement exploitées dans la nature. Enfin, les **bulletins hebdomadaires du CERT-FR** apportent le contexte souverain et les alertes spécifiques aux opérateurs d'importance vitale (OIV) et services essentiels (OSE), qui constituent le périmètre réglementaire de la Marine.

C · Intelligence Gaps & Risks

Cinq trous d'information subsistent, et nous les nommons sans détour. Le plus structurant est l'**absence de cartographie SI ↔ Métier (MOA)** : aucun fichier des datasets ne contient d'arête `asset → process`, alors que c'est précisément ce lien qui transforme un chiffre technique (« 312 actifs compromis ») en décision opérationnelle (« la Maintenance des Navires est à 38 % de dégradation »). Nous le contournerons via **SyntheticMOAMapper**, qui combine la position graphe (PageRank pondéré), le signal sémantique des descriptions d'événements et une distribution-cible métier réaliste, produisant un mapping structurellement plausible en attendant les ateliers MOA officiels.

Le deuxième gap concerne les **transitions TTP → TTP validées** : nous avons les tactics dans la table `nodes_attacks_final.csv` mais pas les enchaînements canoniques observés sur le terrain, donc nous rejeuons les kill chains sur l'ordre standard MITRE avec lateral movement aléatoire entre phases. Le troisième trou concerne l'**état de patch réel par actif** : il n'existe pas dans les données fournies. Nous le simulons via `generate_patch_schedule` selon des fenêtres calibrées sur la pratique industrielle — critical 30–90 jours, high 90–180 jours, medium 180–365 jours, low 365–730 jours — conformes aux recommandations NIST CSF et alignées sur les SLA observés en environnement défense. Le quatrième gap est la **vérification CPE ↔ CVE**, encore prise pour argent comptant : nous savons que cela laisse passer des *targets* non-applicables, et nous prévoyons l'enrichissement via `nvdlib` en phase 3 pour valider que l'actif visé est réellement vulnérable au CPE de la CVE déclarée. Enfin, nous n'avons pas d'**attribution ni de threat intel sur les acteurs** (APT, criminels, hacktivistes) ; nous prévoyons à terme un croisement CISA KEV avec MITRE Groups (Sandworm, CyberAv3ngers, Volt Typhoon) pour enrichir le contexte campagne, étape utile mais non-bloquante pour la détection elle-même.

La règle que nous suivons sur l'ensemble de ces gaps est explicite et auditable : **tout proxy est annoncé comme tel, daté, et conçu pour être remplacé en moins de dix lignes de code** dès que la donnée réelle arrive. Cette discipline garantit que le projet ne s'enferme jamais dans ses propres synthèses et reste prêt à absorber la cartographie MOA, les calendriers de patch SCCM ou le mapping CPE NVD le jour où la Marine les fournit.

Sources : NVD · MITRE ATT&CK v15.1 · CISA KEV · ANSSI CERT-FR · Doctrine ComCyber 2022 · datasets fournis Marine Nationale